MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D10

Control Testing Workbook

Deliverable 10 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Control Testing Workbook

MDM-D10

1. Purpose and Scope

This document tests whether the MDM controls and requirements work as designed. It records the test plan, the test procedures and the results.

It covers a risk-based sample of ten tests. The sample includes controls in MDM-D05, requirements in MDM-D07 and access policies in MDM-D08. It also includes D07 requirements without a D05 control (known gap 1). Requirements not tested are listed in Section 5.

Evidence sufficiency is assessed in MDM-D09. Findings are recorded in MDM-D11. Control readiness is rated in MDM-D13.

No tenant was configured. All results are simulated.

2. Testing Approach

2.1 Sample Selection Basis

Field	Details
Basis	Risk-based. Risk levels are taken from MDM-D04.
High Risks	Two tests each: MDM-RSK-002 and MDM-RSK-005.
Risks Scored 9	One test each: MDM-RSK-001, MDM-RSK-003 and MDM-RSK-007.
Risks Scored 6	**Not tested. Listed in Section 5.**
Known Gap 1	Tested where the requirement covers data removal, the BYOD notice or browser access (MDM-TST-008 to 010).
MDM-D08 Commitments	Assumptions and limitations that MDM-D08 assigns to testing are included, except A-06 (Section 5).
Sample Size	Ten items or fewer: all items are tested. More than ten: ten items are selected. Project-defined.
Automated Checks	When a check can be run on a full report, the full population is tested.
Selected By	GRC Analyst. Providers do not select samples.
Events Not Occurred	No step is designed for an event that did not occur in the period. A documented alternative is tested.

2.2 Roles and Independence

Field	Details
Performs Tests	GRC Analyst, using read-only access (D07 Section 5.4).
Device and Account Steps	IT Operations Team or the enterprise IAM team, under GRC observation.
Reviews Results	CISO.
Independence Exception	Internal Audit reviews MDM-TST-003 and MDM-TST-004. The CISO owns MDM-CTL-005 and performs part of it (D07 Section 5.4). The CISO is informed of the results.
Internal Audit Role	Project-defined for MDM-D10. Not part of the MDM-D02 RACI.
Test Accounts	Administrative test accounts are approved under D07 Section 5.4 and removed after testing.
Basis	MDM-D02; D07 Section 5.4.

2.3 Result Values

Value	Applies To	Meaning
Pass	Step	The actual result matches the expected result.
Fail	Step	The actual result does not match the expected result.
Not Performed	Step	The step could not be performed. The reason is stated. It does not count as a pass.
Effective	Test	All steps passed.
Partially Effective	Test	All key steps passed. At least one other step failed or was not performed.
Not Effective	Test	At least one key step failed or was not performed.

Field	Details
Key Step	A step that tests the objective of the control or requirement itself.
Findings	Each failed step is linked to a finding (MDM-FND-###). Failed steps with one root cause share one finding.

Field	Details
Severity	Finding severity is assessed in MDM-D11, not in the test result.
Control Rating	Controls are rated Implemented, Partial or Not Implemented in MDM-D13.

2.4 Simulation Basis

Field	Details
Basis	The D07 and D08 design was implemented and operated for three months. This is the same basis as MDM-D09 Section 4.
Test Timing	Tests were performed at the end of the period, after the evidence review in MDM-D09.
Exception Sources	Each simulated exception traces to an open item or limitation in MDM-D07 or MDM-D08, a Partial or Not Provided result in MDM-D09, or documented platform behavior. Without a source, the step passes.
Labeling	All results are simulated (TL-01).

3. Test Plan

3.1 Test Coverage

Test ID	Title	Related Risk	Control or Requirement
MDM-TST-001	BYOD data transfer restrictions	MDM-RSK-002	MDM-CTL-002; D07 Sections 4.2–4.5 (MDM-STD-010 to 013)
MDM-TST-002	BYOD access through MDM-CAP-002	MDM-RSK-002	MDM-CTL-002; MDM-CAP-002; D08 A-01, A-04 and L-05
MDM-TST-003	Administrative access approval and review	MDM-RSK-005	MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)
MDM-TST-004	Administrator phishing-resistant MFA	MDM-RSK-005	MDM-CTL-005; MDM-CAP-004; D07 Section 5.3 (MDM-STD-028); D08 A-05
MDM-TST-005	Compliance-based access for corporate	MDM-RSK-	MDM-CTL-003; MDM-CAP-001; D07 Sections 3.3–3.8 (MDM-STD-003 to

Test ID	Title	Related Risk	Control or Requirement
	devices	003	008); D08 A-02 and L-02
MDM-TST-006	Device passcode and immediate lock	MDM-RSK-001	MDM-CTL-001; D07 Sections 3.1–3.2 (MDM-STD-001, 002)
MDM-TST-007	Contractor access revocation	MDM-RSK-007	MDM-CTL-007; D07 Sections 5.7–5.8 (MDM-STD-032, 033)
MDM-TST-008	Corporate wipe and BYOD data removal	None in D04 (known gap 1)	D07 Sections 4.14, 4.15 and 5.9 (MDM-STD-022, 023, 034); NCA ECC 2-6-3-3
MDM-TST-009	BYOD activation gate and privacy notice	None in D04 (known gap 1)	D07 Section 4.17 (MDM-STD-025); D08 Section 3.2 (group membership)
MDM-TST-010	Mobile browser block	None in D04 (known gap 1)	D07 Section 5.10 (MDM-STD-035); MDM-CAP-003; D08 A-03 and L-01

3.2 Evidence and Review Assignments

The GRC Analyst performs all tests. The CISO reviews results, except where independence requires another reviewer (Section 2.2).

Test ID	Evidence Used	Reviewed By
MDM-TST-001	MDM-EVD-004, 005, 055	CISO
MDM-TST-002	MDM-EVD-007, 008, 009	CISO
MDM-TST-003	MDM-EVD-025 to 031	Internal Audit
MDM-TST-004	MDM-EVD-025, 026, 027, 032, 033, 034, 071, 072, 073	Internal Audit
MDM-TST-005	MDM-EVD-010 to 015, 017, 054	CISO
MDM-TST-006	MDM-EVD-001, 002, 003	CISO
MDM-TST-007	MDM-EVD-040, 042, 044 to 047	CISO

Test ID	Evidence Used	Reviewed By
MDM-TST-008	MDM-EVD-004, 005, 058 to 061	CISO
MDM-TST-009	MDM-EVD-009, 062, 063, 064	CISO
MDM-TST-010	MDM-EVD-065, 066	CISO

3.3 Results Summary

Test ID	Test Result	Finding Reference
MDM-TST-001	Not Effective	MDM-FND-001
MDM-TST-002	Not Effective	MDM-FND-002
MDM-TST-003	Not Effective	MDM-FND-003
MDM-TST-004	Effective	None
MDM-TST-005	Partially Effective	MDM-FND-004
MDM-TST-006	Not Effective	MDM-FND-005
MDM-TST-007	Not Effective	MDM-FND-006
MDM-TST-008	Not Effective	MDM-FND-007
MDM-TST-009	Partially Effective	MDM-FND-008
MDM-TST-010	Effective	None

4. Test Procedures and Results

Each test has a details table and a steps table. Key steps follow Section 2.3. All results are simulated.

4.1 MDM-TST-001 BYOD Data Transfer Restrictions

Field	Details
Test ID	MDM-TST-001
Title	BYOD data transfer restrictions
Related Risk	MDM-RSK-002
Control or Requirement	MDM-CTL-002; D07 Sections 4.2–4.5 (MDM-STD-010 to 013)

Field	Details
Objective	Confirm that corporate data in approved apps on BYOD cannot be saved, copied or shared to personal or unapproved destinations.
Evidence Used	MDM-EVD-004, 005, 055
Sample	Two personal test devices: one Android and one iPhone. Each uses a test account in MDM-BYOD-Approved.
Report Sample	Ten users from MDM-EVD-009, selected by the GRC Analyst. Status checked in MDM-EVD-055.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-001

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-004 and 005 with the mappings in D07 Sections 4.2-4.5.	All mapped values are set on both platforms.	All values match.	Yes	**Pass**
2	Review data transfer exemptions in MDM-EVD-004 and 005.	No custom exemption allows transfer to unapproved apps.	No custom exemptions.	Yes	**Pass**
3	Check policy status for the ten sampled users in MDM-EVD-055.	Policy is applied for each user and app.	Policy applied for all ten users.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
4	Save a corporate file from OneDrive to a company SharePoint site. Both platforms.	Save is allowed.	Allowed on both platforms.	No	**Pass**
5	Save a corporate Outlook attachment to local storage and to the photo library. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
6	Save a corporate file to a personal OneDrive account and to a personal cloud storage app. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
7	Copy text from corporate Outlook to corporate Word. Both platforms.	Paste is allowed.	Allowed on both platforms.	No	**Pass**
8	Copy text from corporate Word to an unmanaged notes app. Both platforms.	Paste is blocked.	Blocked on both platforms.	Yes	**Pass**
9	Copy text from an unmanaged notes app to corporate Word. Both platforms.	Paste is allowed.	Allowed on both platforms.	No	**Pass**
10	Copy corporate text to a personal account in Outlook. Both platforms.	Paste is blocked.	Blocked on both platforms.	Yes	**Pass**
11	Paste corporate text into a new unsaved Word document, then save it to local storage. Both platforms.	Save is blocked.	Blocked on both platforms.	Yes	**Pass**
12	Share a corporate file from OneDrive to an unmanaged app. Android.	Transfer is blocked.	Unmanaged apps not offered.	Yes	**Pass**
13	Open a corporate file in an unmanaged app using Open-in. iPhone.	Transfer is blocked.	Unmanaged apps not offered.	Yes	**Pass**
14	Share a corporate file to an unmanaged app using the Share	Transfer is	File transferred.	Yes	**Fail**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	extension. iPhone.	blocked.	The receiving app could not open it.		
15	Remove the device passcode, then open corporate Outlook. iPhone.	The app requires a device passcode before access.	Access blocked until a passcode was set.	Yes	**Pass**
16	Review the app protection log for the encryption setting. Android.	Encryption is shown as applied.	Shown as applied.	No	**Pass**

4.2 MDM-TST-002 BYOD Access Through MDM-CAP-002

Field	Details
Test ID	MDM-TST-002
Title	BYOD access through MDM-CAP-002
Related Risk	MDM-RSK-002
Control or Requirement	MDM-CTL-002; MDM-CAP-002; D08 A-01, A-04 and L-05
Objective	Confirm that approved BYOD users reach corporate services only through protected apps or compliant corporate devices.
Evidence Used	MDM-EVD-007, 008, 009
Sample	One personal Android device and one personal iPhone. One corporate iPhone enrolled in Intune.
Test Account	One test account in MDM-BYOD-Approved, confirmed in MDM-EVD-009.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**

Field	Details
Finding Reference	MDM-FND-002

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-008 with D08 Section 3.2.	Users, exclusions, resources, platforms, grant and state match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Confirm the test account is in MDM-BYOD-Approved, using MDM-EVD-009.	The account is a member.	Member.	No	**Pass**
3	Sign in to each of the six approved apps. Personal Android.	Access is allowed in all six apps.	Allowed in all six apps.	Yes	**Pass**
4	Sign in to each of the six approved apps. Personal iPhone.	Access is allowed in all six apps.	Allowed in all six apps.	Yes	**Pass**
5	Sign in with an app outside the App Protection policies. Both personal devices.	Access is blocked.	Blocked on both devices.	Yes	**Pass**
6	Sign in with a legacy authentication client. Personal Android.	Access is blocked.	Blocked.	Yes	**Pass**
7	Remove Microsoft Authenticator, then sign in to Outlook. Personal iPhone.	User is redirected to the App Store.	Redirected.	No	**Pass**
8	Remove Company Portal,	User is	Redirected.	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	then sign in to Outlook. Personal Android.	redirected to Google Play.			
9	Sign in to Outlook on the corporate iPhone while compliant.	Access is allowed.	Allowed.	No	**Pass**
10	Remove the corporate iPhone passcode to make it noncompliant. Sign in to Outlook.	Access is blocked (A-01).	Blocked.	Yes	**Pass**
11	On the same noncompliant corporate iPhone, sign in to OneDrive without app configuration.	Access is blocked (A-01).	Access allowed through the app protection option.	Yes	**Fail**
12	Repeat Step 11 with the OneDrive app configuration applied.	Access is blocked.	Not performed. No OneDrive app configuration exists (MDM-EVD-007 Not Provided).	Yes	Not Performed

4.3 MDM-TST-003 Administrative Access Approval and Review

Field	Details
Test ID	MDM-TST-003
Title	Administrative access approval and review
Related Risk	MDM-RSK-005
Control or Requirement	MDM-CTL-005; D07 Section 5.4 (MDM-STD-029)
Objective	Confirm that Intune administrative access is approved before assignment, reviewed by the assigned reviewer, and corrected when required.

Field	Details
Evidence Used	MDM-EVD-025 to 031
Grant Sample	All four administrative access grants in the period (MDM-EVD-029). The population is below the sampling threshold.
Review Sample	The most recent quarterly review (MDM-EVD-030).
Performed By	GRC Analyst, using read-only evidence.
Reviewed By	Internal Audit
Test Result	**Not Effective**
Finding Reference	MDM-FND-003

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Reconcile current assignments in MDM-EVD-025 and 026 with the access record in MDM-EVD-028.	Every assignment has a record entry and an approval reference.	All assignments reconciled.	Yes	**Pass**
2	Check the approver of the IT Operations Manager's current access in MDM-EVD-028.	Approved by the CISO.	Approved by the CISO.	Yes	**Pass**
3	Compare approval dates with assignment dates for the four grants.	Each approval precedes its assignment.	All four approvals precede assignment.	Yes	**Pass**
4	Check the approver for the four grants.	Each grant is approved by the IT Operations Manager.	All four approved by the IT Operations Manager.	Yes	**Pass**
5	Check who implemented the four grants.	No grant is implemented by its requester.	No self-implementation.	Yes	**Pass**
6	Compare implemented	Implemented	All four	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	role and scope with the approved role and scope for the four grants.	access matches the approval.	match.		
7	Check review coverage in MDM-EVD-030 against MDM-EVD-025 and 026.	All team assignments are reviewed, including group-derived access.	All team assignments reviewed.	Yes	**Pass**
8	Check the reviewer and decision for team assignments.	IT Operations Manager recorded keep, adjust or remove for each.	Recorded for each assignment.	Yes	**Pass**
9	Check the review of the IT Operations Manager's access.	CISO review recorded, with a decision.	No record of the CISO review.	Yes	**Fail**
10	Trace removals and adjustments from the review to MDM-EVD-031.	Each required change is completed and verified.	Both required changes completed with audit log evidence.	Yes	**Pass**
11	Check access changes from role changes in the period, using MDM-EVD-031.	Access is adjusted without waiting for the quarterly review.	One role change. Access adjusted within two days.	Yes	**Pass**
12	Check GRC Analyst and CISO access in MDM-EVD-025 and 027.	No write access for the GRC Analyst. No Intune administrative access for the CISO.	Read-only access for the GRC Analyst. No access for the CISO.	No	**Pass**

4.4 MDM-TST-004 Administrator Phishing-Resistant MFA

Field	Details
Test ID	MDM-TST-004
Title	Administrator phishing-resistant MFA

Field	Details
Related Risk	MDM-RSK-005
Control or Requirement	MDM-CTL-005; MDM-CAP-004; D07 Section 5.3 (MDM-STD-028); D08 A-05
Objective	Confirm that every account administering Intune must use phishing-resistant MFA, on every access path.
Evidence Used	MDM-EVD-025, 026, 027, 032, 033, 034, 071, 072, 073
Test Accounts	One test account in an MDM-Intune-Admins-* group. One test account holding the Intune Administrator role. Both approved under D07 Section 5.4 and removed after testing.
Log Sample	Ten administrator sign-ins from MDM-EVD-034, selected by the GRC Analyst.
Performed By	GRC Analyst. The enterprise IAM team prepared the test accounts.
Reviewed By	Internal Audit
Test Result	**Effective**
Finding Reference	None

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-033 with D08 Section 3.4.	Groups, roles, exclusions, resources and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Compare Intune RBAC assignments in MDM-EVD-025 with group members in MDM-EVD-026.	Every account with an Intune role is in an included group (A-05).	All accounts are in scope.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
3	Compare holders in MDM-EVD-027 with the roles included in the policy.	Intune Administrator and Global Administrator holders are in scope.	All holders are in scope.	Yes	**Pass**
4	Check method registration for all administrator accounts in MDM-EVD-032.	Each account has a phishing-resistant method registered.	All accounts registered.	No	**Pass**
5	Sign in to the Intune admin center with a phishing-resistant method. RBAC test account.	Access is allowed.	Allowed.	No	**Pass**
6	Sign in to the Intune admin center with a weaker MFA method. RBAC test account.	Access is blocked.	Blocked.	Yes	**Pass**
7	Sign in to the Intune admin center with a weaker MFA method. Entra-role test account.	Access is blocked.	Blocked.	Yes	**Pass**
8	Connect to Microsoft Graph PowerShell with a weaker MFA method. RBAC test account.	Access is blocked.	Blocked.	Yes	**Pass**
9	Review the ten sampled sign-ins in MDM-EVD-034.	Each records phishing-resistant authentication strength as satisfied.	All ten satisfied.	Yes	**Pass**
10	Check emergency account exclusions in MDM-EVD-071.	Emergency accounts are excluded, as designed.	Excluded.	No	**Pass**
11	Compare emergency sign-ins	Each emergency	One sign-in	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	with alerts in MDM-EVD-072 and 073.	sign-in raised an alert.	in the period. Alert raised.		

4.5 MDM-TST-005 Compliance-Based Access for Corporate Devices

Field	Details
Test ID	MDM-TST-005
Title	Compliance-based access for corporate devices
Related Risk	MDM-RSK-003
Control or Requirement	MDM-CTL-003; MDM-CAP-001; D07 Sections 3.3–3.8 (MDM-STD-003 to 008); D08 A-02 and L-02
Objective	Confirm that only compliant corporate devices reach corporate services, and that compliance thresholds are maintained.
Evidence Used	MDM-EVD-010 to 015, 017, 054
Report Population	All corporate devices in MDM-EVD-013. The check is automated, so no sample is needed.
Test Devices	One corporate Android device. One corporate iPad. One newly enrolled device. One enrolled device without a compliance policy. One personal Android device of an employee not approved for BYOD. One personal iPhone of a contractor.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Partially Effective**
Finding Reference	MDM-FND-004

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-010, 011 and 012 with D07 Sections 3.4–3.8.	All mapped values are set.	All values match.	Yes	**Pass**
2	Compare MDM-EVD-017 with D08 Section 3.1.	Users, exclusions, resources, platforms and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
3	Check all devices in MDM-EVD-013 against the OS and patch thresholds.	Every device below a threshold is noncompliant.	All devices below a threshold are noncompliant.	Yes	**Pass**
4	Check devices in MDM-EVD-013 with no report in the last seven days.	Each is noncompliant.	All such devices are noncompliant.	Yes	**Pass**
5	Check monthly baseline reviews in MDM-EVD-014.	One review for each of the three months.	Two reviews. The first month is missing.	No	**Fail**
6	Check the threshold change in MDM-EVD-015.	14 days between approval and enforcement. Users notified. Devices unable to comply identified.	All conditions met.	No	**Pass**
7	Check Android encryption status in MDM-EVD-054.	All Android devices report encryption.	All report encryption.	No	**Pass**
8	Sign in to Outlook. Compliant corporate Android device.	Access is allowed.	Allowed.	No	**Pass**
9	Set the corporate Android	Access is	Blocked.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	device below the patch threshold. Attempt a new sign-in.	blocked.			
10	Update the device, then sign in again.	Access is restored after reassessment.	Restored.	No	**Pass**
11	Remove the passcode on the corporate iPad. Sign in to Teams.	Access is blocked (A-02).	Blocked.	Yes	**Pass**
12	Enroll a new device. Sign in before compliance evaluation completes.	Enrollment succeeds. Access is blocked until evaluation.	Enrolled. Blocked until evaluation.	Yes	**Pass**
13	Sign in from an enrolled device with no compliance policy assigned.	Access is blocked.	Blocked.	Yes	**Pass**
14	Sign in from the personal Android device of an employee not approved for BYOD.	Access is blocked.	Blocked.	Yes	**Pass**
15	Sign in from the personal iPhone of a contractor.	Access is blocked.	Blocked.	Yes	**Pass**
16	Sign in with a legacy authentication client.	Access is blocked.	Blocked.	Yes	**Pass**
17	Keep an Outlook session open during Step 9. Measure the time until it loses access.	Time is recorded (L-02).	Access continued for 6 hours 10 minutes, until token renewal. Within the 28-hour bound in D08 Section 4.2.	No	**Pass**

4.6 MDM-TST-006 Device Passcode and Immediate Lock

Field	Details
Test ID	MDM-TST-006
Title	Device passcode and immediate lock
Related Risk	MDM-RSK-001
Control or Requirement	MDM-CTL-001; D07 Sections 3.1–3.2 (MDM-STD-001, 002)
Objective	Confirm that corporate devices require a strong passcode, lock within five minutes and require authentication immediately after locking.
Evidence Used	MDM-EVD-001, 002, 003
Test Devices	One corporate Android device and one corporate iPhone, both approved models.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-005

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-001 with D07 Section 3.1.	PIN and lock values are set and assigned.	All values match. Assigned.	Yes	**Pass**
2	Compare MDM-EVD-003 with D07 Section 3.2.	Passcode, lock and grace period values are set and assigned.	All values match. Grace period is Immediately. Assigned.	Yes	**Pass**
3	Check MDM-EVD-002 for the approved Android immediate-lock configuration.	A supported configuration is recorded for each selected	No configuration recorded (Not	No	**Fail**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
		model.	Provided).		
4	Set a five-digit PIN. Android.	PIN is rejected.	Rejected.	Yes	**Pass**
5	Set repeated and sequential PINs (111111, 123456). Android.	Both PINs are rejected.	Both rejected.	Yes	**Pass**
6	Set a permitted six-digit PIN. Android.	PIN is accepted.	**Accepted.**	No	**Pass**
7	Leave the device idle. Android.	Device locks within five minutes.	Locked at five minutes.	Yes	**Pass**
8	Wake the device 15 seconds after automatic screen-off. Android.	PIN is required.	Device unlocked without a PIN.	Yes	**Fail**
9	Lock the device with the power button, then wake it. Android.	PIN is required.	PIN required.	Yes	**Pass**
10	Set a five-digit passcode. iPhone.	Passcode is rejected.	Rejected.	Yes	**Pass**
11	Set simple passcodes (111111, 123456). iPhone.	Both passcodes are rejected.	Both rejected.	Yes	**Pass**
12	Set a permitted six-digit passcode. iPhone.	Passcode is accepted.	**Accepted.**	No	**Pass**
13	Leave the device idle. iPhone.	Device locks within five minutes.	Locked at five minutes.	Yes	**Pass**
14	Wake the device 15 seconds after automatic lock. iPhone.	Passcode is required.	Passcode required.	Yes	**Pass**
15	Lock the device with the side button, then wake it. iPhone.	Passcode is required.	Passcode required.	Yes	**Pass**

4.7 MDM-TST-007 Contractor Access Revocation

Field	Details
Test ID	MDM-TST-007
Title	Contractor access revocation
Related Risk	MDM-RSK-007
Control or Requirement	MDM-CTL-007; D07 Sections 5.7-5.8 (MDM-STD-032, 033)
Objective	Confirm that contractor access is revoked at the authorized end time, verified as blocked, and escalated when incomplete.
Evidence Used	MDM-EVD-040, 042, 044 to 047
Departure Sample	All three contractor departures in the period (MDM-EVD-044). The population is below the sampling threshold.
Test Account	One test contractor account with a corporate device, registered in MDM-EVD-040 with a sponsor and end time.
Performed By	GRC Analyst. The IT Operations Team performed account and device steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-006

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Check contractor records in MDM-EVD-040.	Each record has a sponsor, accounts, devices, end time with time zone and an approval reference.	All records complete.	Yes	**Pass**
2	Check reminders in MDM-EVD-042 against the reminder rules in D07	Reminders sent one month before expiry, then weekly, without	Correct for the four weeks	No	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	Section 5.7.	duplicates.	available. Earlier runs are past platform retention.		
3	Check offboarding tasks in MDM-EVD-044 for the three departures.	Each task has the end time, an operator and a backup.	All three complete.	No	**Pass**
4	Compare revocation timestamps in MDM-EVD-045 with end times for the three departures.	Account disabled, sessions revoked and permissions removed at or before the end time.	All three on time.	Yes	**Pass**
5	Check access block verification in MDM-EVD-046 for the three departures.	Effective blocking is verified for each. Account status alone is not accepted.	Two verified. One shows account status only.	Yes	**Fail**
6	Check escalation of the incomplete verification in Step 5, using MDM-EVD-047.	The incomplete action is escalated to the IT Operations Manager.	Not escalated.	No	**Fail**
7	At the test end time, disable the test account and revoke sessions. Attempt a new sign-in.	Access is blocked.	Blocked.	Yes	**Pass**
8	Keep an Outlook session open during Step 7. Measure the time until it loses access.	Time is recorded (D08 Section 4.2).	Access lost after 3 minutes.	No	**Pass**
9	Record an early departure for the test account. Revoke at the revised time.	Access is revoked at the revised time.	Revoked at the revised time.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
10	Set an end time outside working hours, with the primary operator marked absent.	The backup operator revokes access at the end time.	Revoked by the backup on time.	Yes	**Pass**

4.8 MDM-TST-008 Corporate Wipe and BYOD Data Removal

Field	Details
Test ID	MDM-TST-008
Title	Corporate wipe and BYOD data removal
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Sections 4.14, 4.15 and 5.9 (MDM-STD-022, 023, 034); NCA ECC 2-6-3-3
Objective	Confirm that corporate data is removed from BYOD apps and corporate devices when required, that removal is verified, and that personal data is preserved.
Evidence Used	MDM-EVD-004, 005, 058 to 061
Record Population	All records in the period: five selective wipe requests (MDM-EVD-058), six corporate wipes (MDM-EVD-059), one reported loss (MDM-EVD-060) and four reassigned devices (MDM-EVD-061). Each population is below the sampling threshold.
Test Devices	One personal Android device and one personal iPhone, with test accounts in MDM-BYOD-Approved. One corporate Android device and one corporate iPhone.
Offline Test Policy	A copy of the production App Protection policy, with Offline grace period = 1 day. Assigned to the test accounts only.
Performed By	GRC Analyst. The IT Operations Team performed device and wipe steps under GRC observation.
Reviewed By	CISO
Test Result	**Not Effective**
Finding Reference	MDM-FND-007

Field	Details

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare offline settings in MDM-EVD-004 and 005 with D07 Section 4.14.	Offline grace period = 90 days, Action = Wipe data. The 1440-minute block is retained.	All values match.	Yes	**Pass**
2	Check the five selective wipe requests in MDM-EVD-058.	Each has a verified target, a request date and per-app completion. Unresolved requests are tracked.	All five complete. No unresolved requests.	Yes	**Pass**
3	Check the six corporate wipes in MDM-EVD-059.	Each has a command date, result and confirmation.	All six confirmed.	Yes	**Pass**
4	Check the four reassigned devices in MDM-EVD-061.	Reset inspected, re-enrolled and compliant before access.	All four complete.	Yes	**Pass**
5	Check the reported loss in MDM-EVD-060.	Wipe issued without waiting for recovery.	Wipe issued on the day of the report.	Yes	**Pass**
6	Check wipe completion for the reported loss.	Wipe completion is confirmed.	No confirmation recorded.	Yes	**Fail**
7	Check follow-up for the unconfirmed wipe.	Kept open with an owner and a follow-up date.	No owner or follow-up date recorded.	No	**Fail**
8	Submit a device-based selective wipe. Personal Android.	Corporate data removed from each app. Personal data preserved.	Removed from all apps. Personal data	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
			preserved.		
9	Submit a user-level selective wipe. Personal iPhone.	Corporate data removed from each app. Personal data preserved.	Removed from all apps. Personal data preserved.	Yes	**Pass**
10	Submit a selective wipe while the device is offline. Reconnect it. Personal Android.	Request stays pending, then completes on reconnection.	Pending, then completed.	No	**Pass**
11	Keep a test app offline past the test period. Fail reauthentication. Both personal devices.	Work account and app data removed. Personal data preserved.	Removed on both platforms. Personal data preserved.	Yes	**Pass**
12	Keep a test app offline past the test period. Reauthenticate successfully. Both personal devices.	Access restored. The offline interval resets.	Restored on both platforms.	No	**Pass**
13	Wipe the corporate Android device. Inspect, re-enroll and check compliance.	Device reset. No previous-user data. Compliant before access.	All conditions met.	Yes	**Pass**
14	Wipe the corporate iPhone. Inspect, re-enroll and check compliance.	Device reset. Activation Lock does not block re-enrollment. Compliant before access.	All conditions met.	Yes	**Pass**

4.9 MDM-TST-009 BYOD Activation Gate and Privacy Notice

Field	Details
Test ID	MDM-TST-009
Title	BYOD activation gate and privacy notice

Field	Details
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Section 4.17 (MDM-STD-025); D08 Section 3.2 (group membership)
Objective	Confirm that BYOD is activated only after notice acknowledgment, manager approval and technical checks, and that the notice matches the information the company can see.
Evidence Used	MDM-EVD-009, 062, 063, 064
Membership Population	All members of MDM-BYOD-Approved (MDM-EVD-009), reconciled with activation records (MDM-EVD-063). The check is automated, so no sample is needed.
Record Sample	Ten activation records from MDM-EVD-063, selected by the GRC Analyst.
Test Requests	Four BYOD activation requests from test accounts, on one personal Android device and one personal iPhone.
Performed By	GRC Analyst. The IT Operations Team processed test requests under GRC observation.
Reviewed By	CISO
Test Result	**Partially Effective**
Finding Reference	MDM-FND-008

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Check the notice in MDM-EVD-062 against the content required by D07 Section 4.17.	The notice covers visible information, purposes, access, restrictions, data removal and support contact. Version history exists.	All content present. Version history exists.	Yes	**Pass**
2	Compare information visible in Intune for the	Visible information	Matches on both	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	test accounts with the notice. Both platforms.	matches the notice.	platforms.		
3	Reconcile all MDM-BYOD-Approved members with activation records.	Every member has an activation record.	All members reconciled.	Yes	**Pass**
4	Check the ten sampled records for required fields.	Identity, notice version, acknowledgment time, manager approval, IT Operations verification and activation date are present.	All ten complete.	Yes	**Pass**
5	Compare acknowledgment and approval dates with group addition dates for the ten records.	Both precede the date the user was added to the group.	All ten precede.	Yes	**Pass**
6	Check the notice version in the ten records against MDM-EVD-062.	The version acknowledged was current at the time.	All ten current.	No	**Pass**
7	Check repository permissions in MDM-EVD-064.	Access is limited to authorized roles.	Limited to authorized roles.	No	**Pass**
8	Check the retention setting in MDM-EVD-064.	A retention period is set.	No retention period set.	No	**Fail**
9	Submit a test request without acknowledgment.	Activation is refused.	Refused.	Yes	**Pass**
10	Submit a test request without manager approval.	Activation is refused.	Refused.	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
11	Submit a test request from a device below the BYOD OS minimum.	Activation is refused.	Refused.	Yes	**Pass**
12	Submit a complete test request.	Activation completed. User added to the group. Access works.	Activated. Added. Access works.	No	**Pass**

4.10 MDM-TST-010 Mobile Browser Block

Field	Details
Test ID	MDM-TST-010
Title	Mobile browser block
Related Risk	None in D04 (known gap 1)
Control or Requirement	D07 Section 5.10 (MDM-STD-035); MDM-CAP-003; D08 A-03 and L-01
Objective	Confirm that mobile browsers cannot reach corporate services, while approved app sign-in and enrollment flows still work.
Evidence Used	MDM-EVD-065, 066
Test Devices	One personal Android device and one personal iPhone, with test accounts in MDM-BYOD-Approved. One corporate Android device. One corporate iPhone, before ADE enrollment. One corporate iPad.
Performed By	GRC Analyst. The IT Operations Team performed device steps under GRC observation.
Reviewed By	CISO
Test Result	**Effective**
Finding Reference	None

Test Steps

Step	Procedure	Expected Result	Actual Result	Key Step	Result
1	Compare MDM-EVD-065 with D08 Section 3.3.	Users, exclusions, resources, platforms, client apps and grant match the design. Policy state is On.	All settings match. State is On.	Yes	**Pass**
2	Compare MDM-EVD-066 with D07 Section 5.10.	The six approved apps are assigned with corporate account configuration.	All six assigned and configured.	No	**Pass**
3	Open Outlook on the web in Chrome. Personal Android.	Access is blocked.	Blocked.	Yes	**Pass**
4	Open SharePoint and OneDrive in Safari. Personal iPhone.	Access is blocked.	Blocked.	Yes	**Pass**
5	Open Outlook on the web in Microsoft Edge with App Protection. Corporate Android.	Access is blocked.	Blocked.	Yes	**Pass**
6	Sign in to the Outlook app after Steps 3–5. All three devices.	Access is allowed.	Allowed on all three.	Yes	**Pass**
7	Sign in through an in-app web view in Teams. Check the sign-in log.	Access is allowed. Logged as Mobile apps and desktop clients (A-03).	Allowed. Logged as Mobile apps and desktop clients.	Yes	**Pass**
8	Open a SharePoint document link and an Outlook on the web link from Teams. Personal iPhone.	The document opens in an approved app. The web link is blocked in the browser.	Document opened in OneDrive. Web link blocked.	No	**Pass**
9	Request the desktop site	Access is blocked by	Logged as	Yes	**Pass**

Step	Procedure	Expected Result	Actual Result	Key Step	Result
	in Safari and open Outlook on the web. Personal iPhone.	MDM-CAP-003 or by enterprise desktop policies (L-01).	macOS. Blocked by an enterprise desktop policy.		
10	Open Outlook on the web in Safari with default settings. Corporate iPad.	Access is blocked by MDM-CAP-003 or by enterprise desktop policies (L-01).	Logged as macOS. Blocked by an enterprise desktop policy.	Yes	**Pass**
11	Enroll the corporate iPhone through ADE. Sign in to Company Portal and register security information.	All three flows succeed.	All three succeeded.	No	**Pass**

5. Requirements Not Tested

The sample covers all High risks and all risks scored 9 (Section 2.1). The requirements below were not tested. Requirements with a known evidence deficiency in MDM-D09 are carried to MDM-D11. Others are retained for the next test cycle.

Requirement	Related Risk	Reason Not Tested	D09 Evidence	Handling
MDM-CTL-004 Access policy change management	MDM-RSK-004 (6, Medium)	Below the sample threshold.	MDM-EVD-023 Not Provided	Carried to MDM-D11.
MDM-CTL-006 Device report access control	MDM-RSK-006 (6, Medium)	Below the sample threshold. No expansion, per project scope.	MDM-EVD-035 to 039 Accepted	Next test cycle.
MDM-CTL-008 Device compliance report accuracy	MDM-RSK-008 (6, Medium)	Below the sample threshold. No expansion, per project scope.	MDM-EVD-049 to 053 Accepted	Next test cycle.
D07 Sections 4.6–4.13	MDM-RSK-	The sample tested transfer	MDM-EVD-	Next test

Requirement	Related Risk	Reason Not Tested	D09 Evidence	Handling
and 4.16 (MDM-STD-014 to 021, 024) BYOD app-level protections	002	routes (MDM-TST-001) and access (MDM-TST-002). App-level behavior was not tested.	004, 005 Accepted	cycle.
D07 Section 5.1 (MDM-STD-026) Corporate data protection in transit	None in D04 (known gap 1)	Network path not reviewed. A device-side test cannot show proxy or TLS inspection.	MDM-EVD-057 Not Provided	Carried to MDM-D11.
D07 Section 5.2 (MDM-STD-027) Permission and scope behavior	MDM-RSK-005	Assignments were reconciled in MDM-TST-003. Permission behavior was not tested. Priority for the next cycle (High risk).	MDM-EVD-025, 027, 028 Accepted	Next test cycle.
D08 Section 4.5, assumption A-06 (enterprise user MFA)	Enterprise dependency	IAM owner coverage confirmation not provided.	MDM-EVD-069 Partial	Recorded as a gap in MDM-D11, per MDM-D08.

6. Assumptions and Limitations

6.1 Assumptions

ID	Assumption	Affects
TA-01	Test devices and test accounts receive the same policies and assignments as production users.	All device steps
TA-02	Configurations did not change between evidence collection (MDM-D09) and testing.	All configuration comparison steps

6.2 Limitations

ID	Limitation	Affects	Handling
TL-01	No tenant was configured. All results are simulated.	All tests	Marked as simulated (MDM-D08 L-08).
TL-02	Device tests show behavior on the test date only.	All device steps	Period records are tested where available.

ID	Limitation	Affects	Handling
TL-03	Android BYOD encryption cannot be verified directly.	MDM-TST-001, Step 16	The app protection log shows the setting as applied. Not a key step.
TL-04	iOS/iPadOS does not report encryption status at device level.	MDM-TST-005, Step 7	Android status tested. iOS/iPadOS relies on the passcode requirement (Step 11).
TL-05	Integrity failure handling was not tested on a compromised device.	MDM-TST-005	Policy setting checked in Step 1.
TL-06	Power Automate keeps run history for 28 days by default.	MDM-TST-007, Step 2	Reminders tested for the last four weeks only.
TL-07	The 90-day offline period could not be observed during testing.	MDM-TST-008, Steps 11–12	Tested with a one-day test policy. The mechanism was tested, not the 90-day value.
TL-08	IT Operations processed test requests knowing they were tests.	MDM-TST-009, Steps 9–12	Step 5 tests real activation records from the period.
TL-09	Desktop-site protection relies on enterprise policies outside project scope.	MDM-TST-010, Steps 9–10	Observed in sign-in logs only. Not evidenced in MDM-D09.

7. Sources

All Microsoft Learn pages were reviewed on 7 November 2026.

Source	Used In
MDM-D02 Stakeholder and RACI Matrix	2.2
MDM-D04 Risk Assessment Methodology and Risk Register	2.1, 3
MDM-D05 Control Requirements and Framework Crosswalk	3, 4
MDM-D07 MDM Security Standard	3, 4, 5, 6
MDM-D08 Conditional Access Control Design	3, 4, 5, 6
MDM-D09 Evidence Request List and Evidence Index	3, 4, 5
NCA Essential Cybersecurity Controls (ECC-2:2024) - https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-	3, 4.8

Source	Used In
355673607654_ECC--2024-EN.pdf	
Microsoft Learn: iOS app protection policy settings - https://learn.microsoft.com/en-us/intune/apps/app-protection-policy-settings-ios	4.1
Microsoft Learn: Missing runs or triggers history for a flow - https://learn.microsoft.com/en-us/troubleshoot/power-platform/power-automate/flow-run-issues/missing-runs-or-triggers-history-for-a-flow	4.7, 6